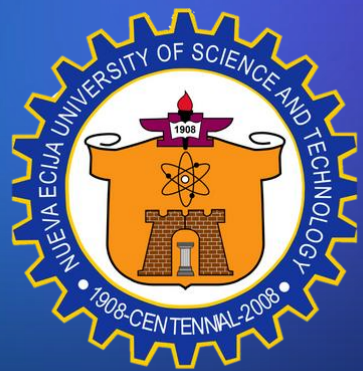




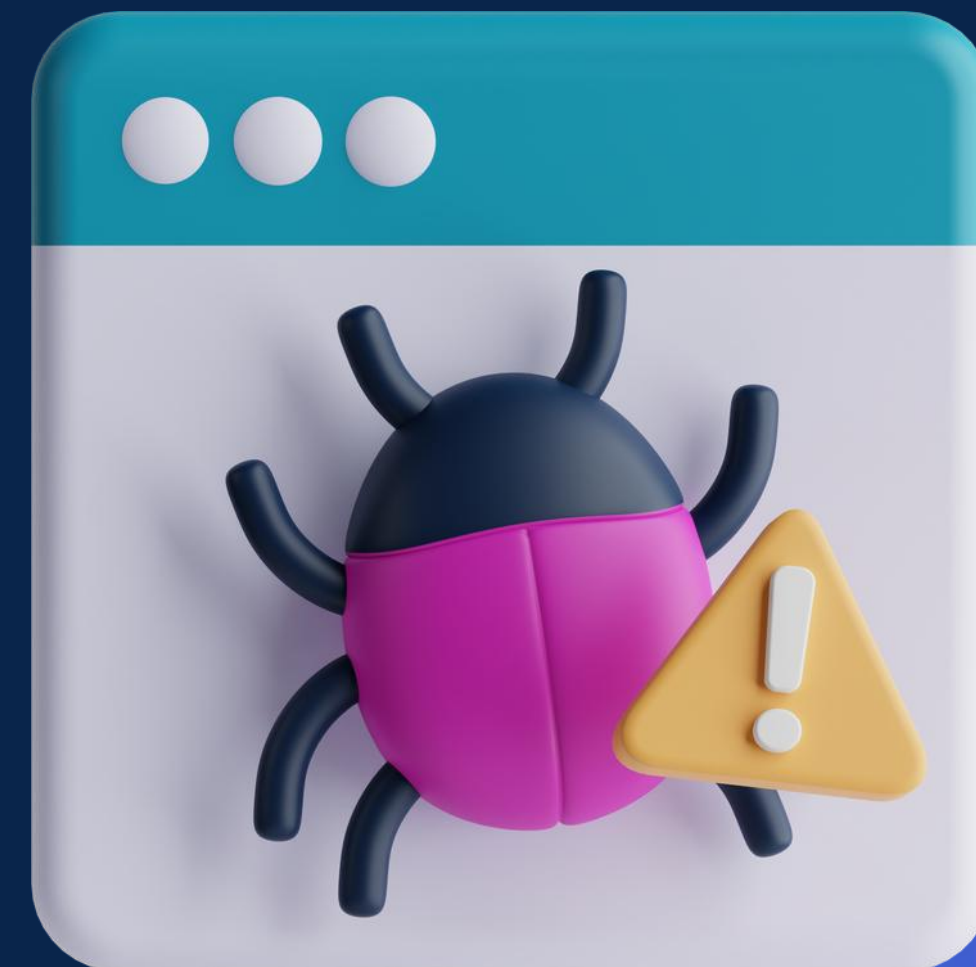
REPUBLIC OF THE PHILIPPINES
NUEVA ECIJA UNIVERSITY OF SCIENCE AND TECHNOLOGY
COLLEGE OF INFORMATION AND COMMUNICATIONS TECHNOLOGY



ITWS - 04

WEBSYSTEMS VULNERABILITIES

PREPARED BY:
JOHN PHILLIP M. MEDINA

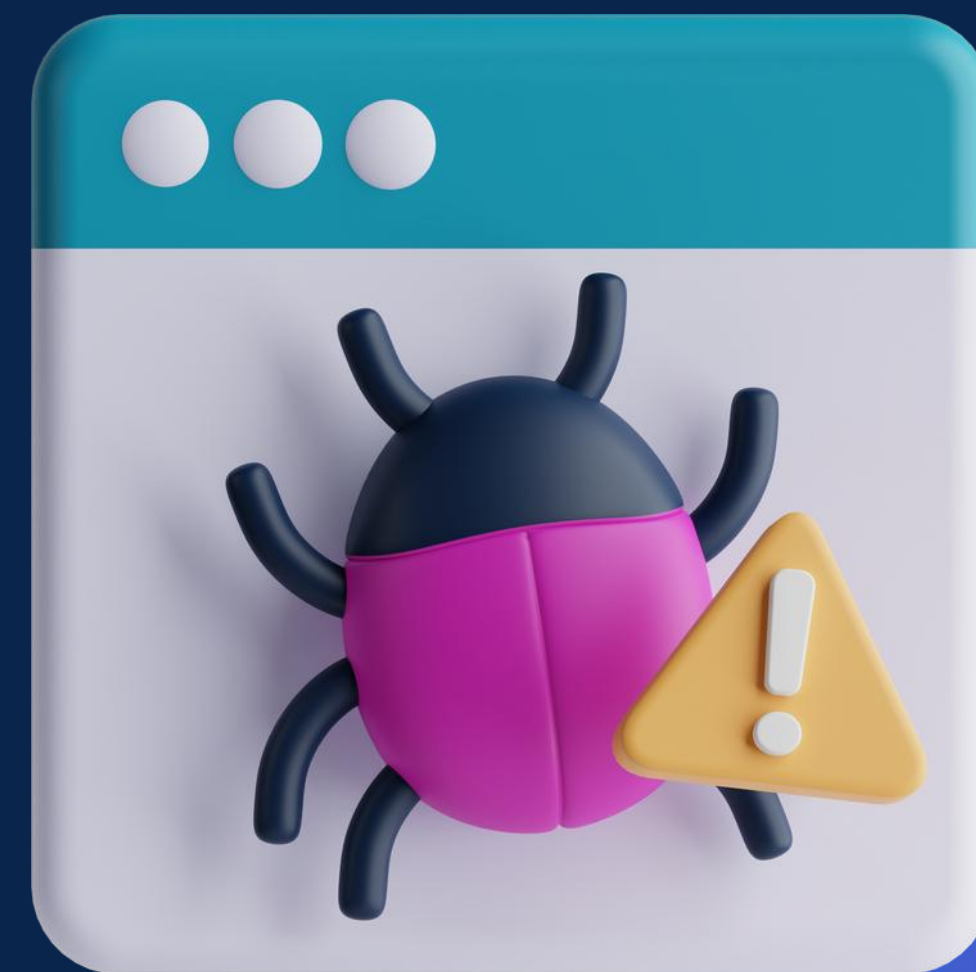




REPUBLIC OF THE PHILIPPINES
NUEVA ECIA UNIVERSITY OF SCIENCE AND TECHNOLOGY
COLLEGE OF INFORMATION AND COMMUNICATIONS TECHNOLOGY

LESSON 1

INTRODUCTION TO WEB VULNERABILITIES

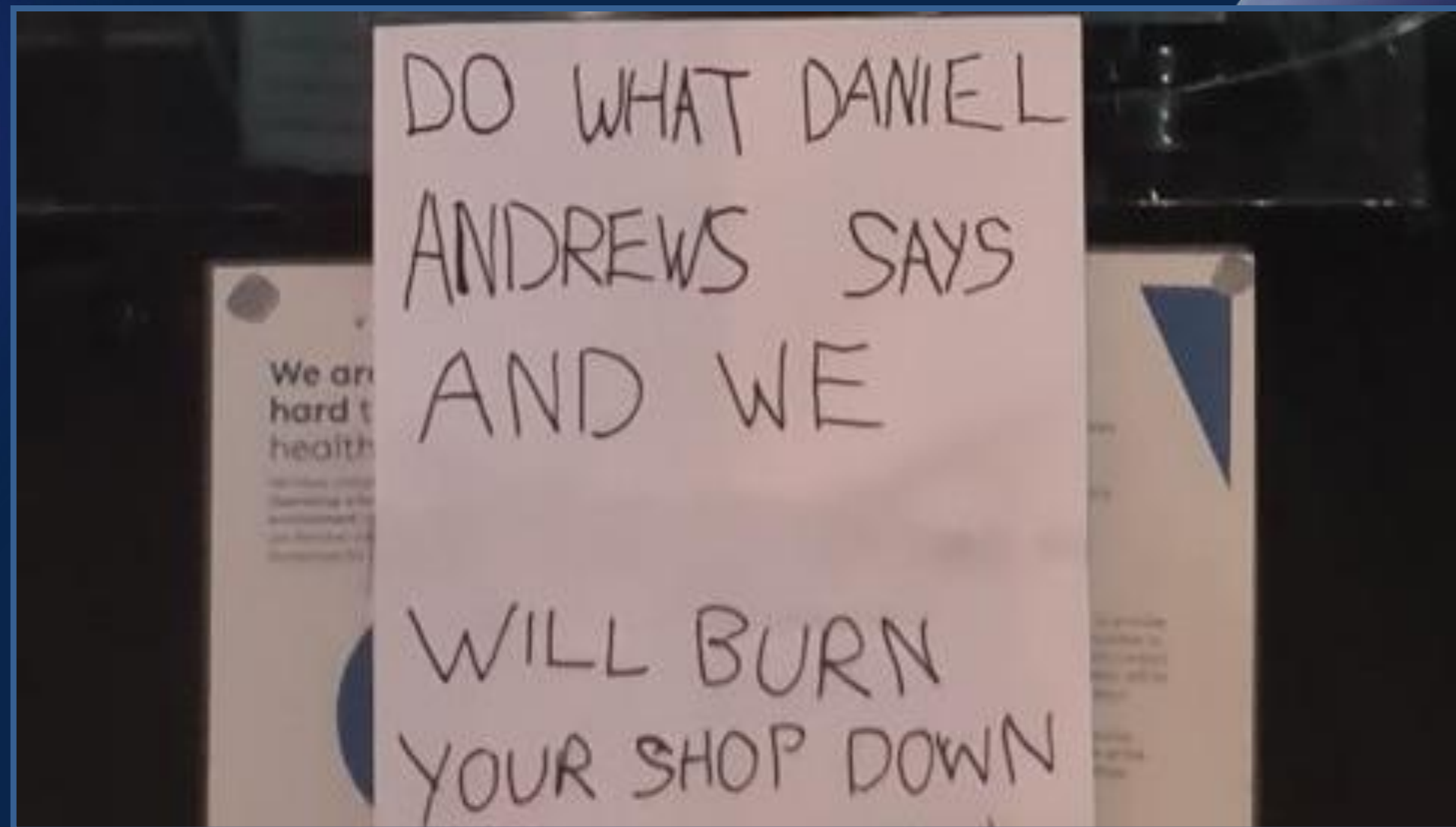
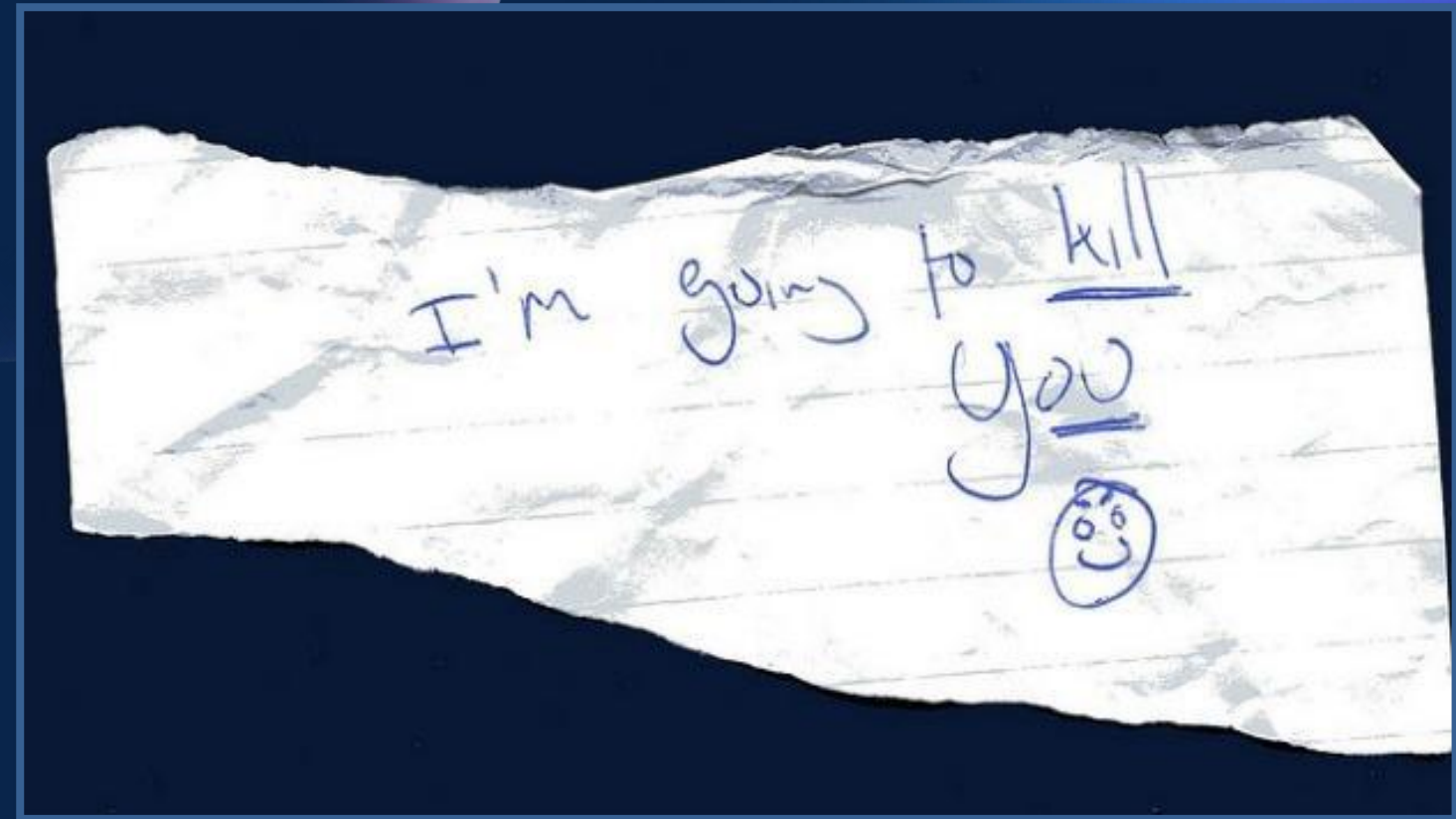


LESSON OBJECTIVES

- 01** Define and have an understanding of the terms threat, vulnerability, attack and web application vulnerability
- 02** Explain the anatomy of an attack by describing its five stages
- 03** Explain why web systems become vulnerable



WHAT IS AN **ASSET**?



WHAT IS A **THREAT**?

A **threat** is any potential event that could harm an asset, malicious or otherwise. In other words, any bad thing that can happen to an asset is a **threat**.

A threat is a statement of an intent to harm or punish, or something that presents an imminent danger or harm.

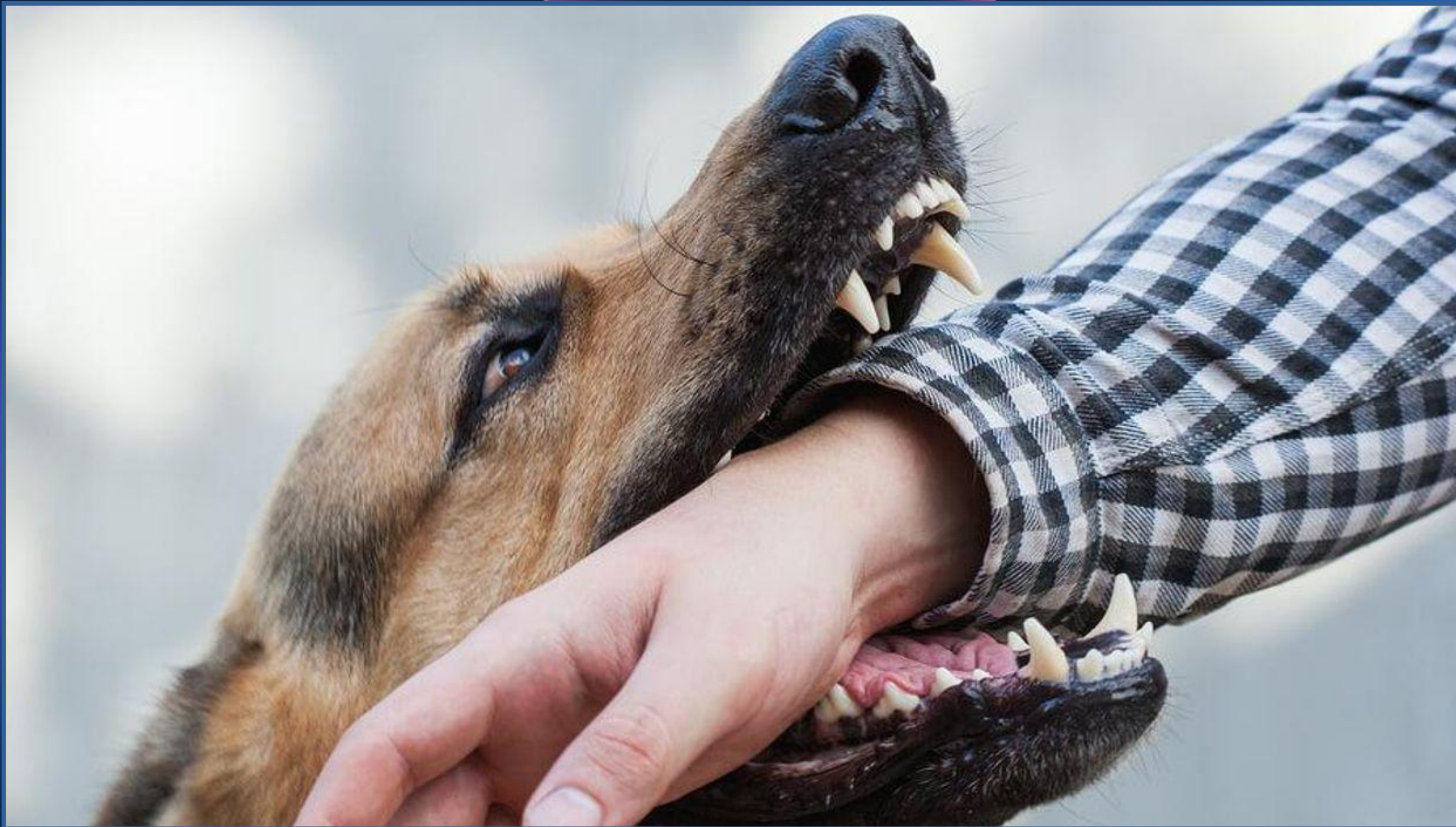


WHAT IS A **VULNERABILITY**?

A **vulnerability** is a weakness which allows an attack.

This may be due to poor design, configuration errors or improper and insecure coding techniques.

Low input validation is an example of a weakness in an application layer which can lead to input attacks.



WHAT IS A ATTACK?

An attack happens when a threat exploits a vulnerability.

Examples: Sending malicious input to an app, or flooding a network to attempt to deny service.



Anonymous Philippines

Greetings Philippines! We are Anonymous.

The Constitution so asserts that "Sovereignty resides in the people and all government authority emanates from them."
One of the processes by which people exercise their sovereignty is through voting in an election- where people choose the candidates who will best represent them, who will serve them under the principle that "Public office is a public trust."

But what happens when the electoral process is so mired with questions and controversies?

Can the government still guarantee that the sovereignty of the people is upheld?

We request the implementation of the security features on the PCOS machines.

Commission on Elections, We are watching!

We are Anonymous,
We are legion,
We do not forgive,
We do not forget.

EXPECT US!

Are you a concerned citizen? Mail us at info@anonph.net

-n3farious | ./kh4lifax | sec.anonops

Anonymous Philippines - Phantom Hackers.PH - Philippine Cyber Army - PrivateX

The breach was later called "Comeleak" after the hackers obtained the personal information of over 55 million registered voters, including names, birthdays, home and e-mail addresses and parents' full names.

*To sum up, a **threat** is a future occurrence that can adversely affect an asset, while the **vulnerability** in your system is exploited by a successful **attack**.*

Read each statement carefully. Identify if it is a **Threat**, a **Vulnerability**, or an **Attack**.

Corrupt officials and contractors intend to misuse public funds by prioritizing personal gain over public safety.

Read each statement carefully. Identify if it is a **Threat**, a **Vulnerability**, or an **Attack**.

A government flood control project is identified as an easy target because of weak oversight, poor auditing, and lack of transparency.

Read each statement carefully. Identify if it is a **Threat**, a **Vulnerability**, or an **Attack**.

The corrupt group executes the project using substandard materials, inflated costs, and falsified inspection reports, while officially declaring the project “completed.”

WHAT IS A WEB APPLICATION?



A **web application** (or web app) is application software that is accessed using a web browser.

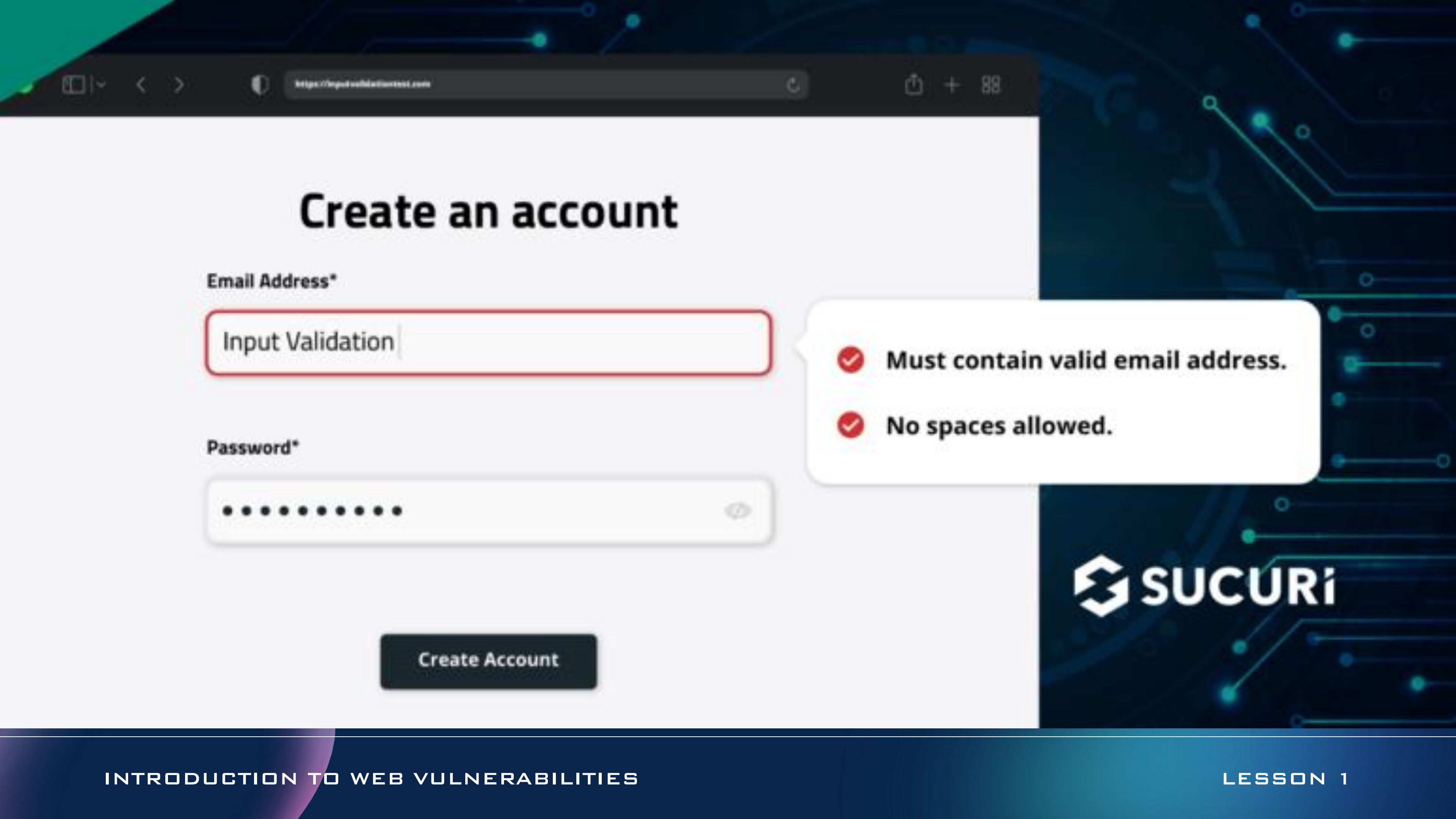
WHAT IS A WEB APPLICATION VULNERABILITY?

A **web application vulnerability** is a weakness or misconfiguration in a website or web application code that enables an attacker to gain some level of control of the site, and possibly the hosting server.

Most vulnerabilities are exploited through automated means, such as vulnerability scanners and botnets.

WHY SYSTEM IS **VULNERABLE**?

- not validating or sanitizing form inputs,
- misconfigured web servers
- application design flaws



https://inputvalidationtest.com

Create an account

Email Address*

Password*

Create Account

- ✓ Must contain valid email address.
- ✓ No spaces allowed.



phpMyAdmin

localhost ▶ testsite ▶ users

Browse Structure SQL Search Insert Export Import Operations Empty Drop

Showing rows 0 - 2 (~3¹ total, Query took 0.0003 sec)

```
SELECT *  
FROM `users`  
LIMIT 0, 30
```

Profiling [Edit] [Explain SQL] [Create PHP Code] [Refresh]

Show: 30 row(s) starting from record # 0
in horizontal mode and repeat headers after 100 cells
Sort by key: None
+ Options

			Id	Name	Email	Password
☐			15	Some Name	some@email.com	Password
☐			16	Any Name	any@email.com	Password
☐			17	Ijaz	ijaz@email.com	Password

Check All / Uncheck All With selected:

Show: 30 row(s) starting from record # 0
in horizontal mode and repeat headers after 100 cells

Query results operations

Print view Print view (with full texts) Export CREATE VIEW

Bookmark this SQL query

Label: ☐ Let every user access this bookmark

Bookmark this SQL query

¹ May be approximate. See FAQ 3.11

① 192.168.1.3/bWAPP/sql_1.php?title=a' order by 10 --+

ing Started

Connect to Server



Cannot connect to 001.SQLSRV.WIN2K16\SQLEXPRESS.

Additional information:

... Login failed for user 'sa'. (Microsoft SQL Server, Error: 18456)



OK

ANATOMY OF AN ATTACK

An attack is composed of 5 stages:

01 *Survey and Assess*

02 *Exploit and Penetrate*

03 *Escalate Privileges*

04 *Maintain Access*

05 *Deny Service*



1. SURVEY AND ASSESS

Surveying and assessing of the future target are performed in parallel. The first step normally taken by an intruder is to survey the possible target to **define and assess its characteristics.**

These characteristics can include its supported services and protocols along with possible vulnerabilities as well as entry points. To plan an initial attack, the attacker uses the **information gathered in the survey and assess phase.**

2. EXPLOIT AND PENETRATE

Having assessed the potential target, the next move is to **exploit and penetrate**. If the network and host are completely protected, then the next platform for attack will be your application.

The easiest way for an attacker to get into an application is through the same entrance that legitimate users use.

For example, through the log on page of the application or a page that does not require authentication.

3. ESCALATE PRIVILEGES

After attackers managed to enter an application or network by injecting code into the application or creating an authenticating session with the operating system. They will immediately try to **escalate privileges**.

In particular, they are looking for **administrative rights** that are offered by accounts that are members of the Administrators group. They are just searching for the **high degree of rights** the local network account provides.

4. MAINTAIN ACCESS

When an intruder has obtained access to a network, he takes steps to encourage future access and cover his or her tracks.

Popular approaches to encouraging potential access and making them easier include planting of backdoor programs or the use of an established account lacking strong security. Usually, covering tracks includes clearing logs, and hiding tools.

Log files should be secured, and should be periodically examined. Analysis of the log file will also show the early signs of an attempted break-in before the harm is done.

5. DENY SERVICE

Attackers who are unable to get access also launch a **denial-of- service** attack to **discourage** anyone from using the device. For other attackers, their target from the beginning is the denial of service to the application.

DOS - Denial of Service

DDOS – Distributed Denial of Service

ANATOMY OF AN ATTACK

An attack is composed of 5 stages:

01 *Survey and Assess*

02 *Exploit and Penetrate*

03 *Escalate Privileges*

04 *Maintain Access*

05 *Deny Service*



SAMPLE CASE: SHOPPRO E-COMMERCE WEBSITE

An e-commerce platform, ShopPro, has been targeted by a malicious hacker group. The group uses various techniques to compromise the website and achieve their objectives. Below is a description of the attack process:

Survey and Assess: The attacker starts by gathering information about the website. Using various tools, they identify that the website runs on an outdated version of a popular CMS (Content Management System). They also discover that the server exposes unnecessary open ports

SAMPLE CASE: SHOPPRO E-COMMERCE WEBSITE

Exploit and Penetrate:

After identifying the vulnerabilities, the attacker crafts a malicious payload to exploit a known vulnerability in the CMS. By submitting this payload through the login page, they bypass authentication and gain access to the administrative dashboard of the website.

Escalate Privileges: Once inside the system, the attacker notices that the admin dashboard has overly permissive access controls. They exploit this by modifying configurations to grant themselves "super admin" privileges, allowing access to sensitive customer data and payment details

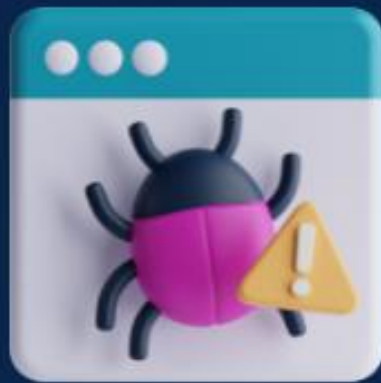
SAMPLE CASE: SHOPPRO E-COMMERCE WEBSITE

Maintain Access: The attacker installs a backdoor on the server, allowing them to re-enter the system later without detection. They also create a hidden "ghost admin" account to ensure persistent access even if the initial breach is discovered.

Deny Service: To cover their tracks and distract the IT team, the attacker launches a DDoS attack, flooding the server with traffic from a botnet. This causes the website to become unresponsive, preventing legitimate users from accessing it

THANK YOU

-END-



ITWS - 04

WEB SYSTEMS VULNERABILITIES

REFERENCES



IT-WS01:WEB SYSTEMS AND
TECHNOLOGIES 1 –MODULE 2026

PRESENTATION BY:
JOHN PHILLIP M. MEDINA
